

7. Riesgos, límites y gobernanza del sistema

7.1. Top 5 riesgos más críticos

A partir del análisis de riesgos de tu documento (sesgos, fatiga de alertas, decisiones punitivas, etc.) y del marco IA Act + RGPD, se identifican como más críticos:

1. **Riesgo de sesgos y trato desigual a colectivos vulnerables**
 - El modelo podría generar **más falsas alertas** o **menos detecciones** para ciertos grupos (personas mayores, con discapacidad motora o vocal, interseccionalidad), vulnerando el principio de **igualdad y no discriminación** y el **art. 10 de la IA Act** (calidad y ausencia de sesgos).
 - Referencias: sección 8 del PDF (usuarios y colectivos afectados, Equalized Odds < 5 %), [AI Act Explorer](#).
2. **Riesgo de uso punitivo y decisiones casi automáticas**
 - Que las alertas se utilicen como **justificación casi automática** para sanciones, aislamientos, cambios de módulo o restricciones de derechos, vaciando de contenido el requisito de **supervisión humana efectiva** (art. 14 IA Act) y vulnerando el **principio de reinserción** (art. 25.2 CE).
 - Riesgo de que el sistema se convierta de facto en un **“tribunal algorítmico”**, algo que vuestro documento rechaza explícitamente.
3. **Fatiga de alertas y efectos perversos en la seguridad**
 - Si el sistema genera demasiados **falsos positivos**, el personal puede:
 - Ignorar sistemáticamente las alertas (desensibilización).
 - O actuar de forma defensiva (más cacheos, más tensión) aumentando el mal clima.
 - Esto va contra el objetivo central de **mejorar la seguridad** y se relaciona con los umbrales de FAR y FPR que fijáis (FP < 12 %, FAR ≤ 0,25 FP / cámara / 24 h para despliegue a escala).
4. **Riesgo de ampliación de finalidad (“function creep”)**
 - Que, una vez desplegado, se intente usar el sistema para:
 - **Identificación de personas**, vigilancia política o religiosa, o perfilado de peligrosidad individual.
 - Otros contextos (espacio público, empresas) no previstos.
 - Esto vulneraría el principio de **limitación de finalidad** (art. 5 RGPD) y las restricciones que habéis definido en los “usos no previstos”.
5. **Riesgo de falsa sensación de seguridad o opacidad técnica**
 - Confiar excesivamente en el modelo, obviando sus límites (zonas sin cobertura, situaciones OOD, degradación en condiciones adversas).
 - Si no se mantiene la **explicabilidad**, la documentación y las auditorías, se genera una **caja negra** incompatible con las obligaciones de transparencia (art. 13 IA Act) y con el enfoque safetyist que defendéis (transparencia + verificabilidad + auditoría externa).

Fuentes generales:

- [Maldita.es – Ley de IA en la UE](#)

- [AI Act Explorer](#)
- [Youreurope – Data Protection \(RGPD\)](#)

7.2. Líneas rojas y “botón de parada” de emergencia

En coherencia con el enfoque **safetyist** de vuestra “Postura macro”, se definen **líneas rojas** y un mecanismo claro de **parada de emergencia**:

Líneas rojas (cuando el sistema NO debe usarse)

- 1. Uso para identificación biométrica o reconocimiento individual**
 - Cualquier intento de usar el sistema para **reconocer rostros, voces o identidades** de internos excede por completo su diseño y vulnera:
 - Las advertencias de la Comisión Europea, EDPB y EDPS sobre biometría en contextos de alto riesgo (citadas en la parte de “Tratamiento de imágenes/lecturas biométricas”).
 - Las bases legales del tratamiento (art. 9.2.g RGPD) acordadas en la sección de privacidad.
- 2. Uso como prueba principal en sanciones o decisiones de alto impacto**
 - Las alertas **no pueden ser el único ni principal fundamento** para:
 - Sanciones disciplinarias.
 - Traslados a módulos de mayor seguridad.
 - Denegación de permisos de salida o progresiones de grado.
 - Cualquier uso de este tipo vulneraría el marco de **supervisión humana efectiva** (art. 14 IA Act) y el principio de **proporcionalidad** (RGPD, LOPD-GDD).
- 3. Métricas por debajo de los umbrales Go/No-Go definidos**
 - Si en explotación real el sistema cae por debajo de:
 - **Recall $\geq 0,90$** (o 0,95 para despliegue a escala).
 - **FP $< 12\%$, FAR ≤ 1 FP / cámara / 24 h** (o 0,25 para escala).
 - **Equalized Odds $< 5-10\%$** entre subgrupos.
 - Entonces **no debe seguir operando con el mismo alcance**; el propio documento establece que sin el Nivel C no puede haber despliegue masivo.
- 4. Evidencias de sesgo grave o discriminación sistemática**
 - Si auditorías internas/externas o quejas repetidas muestran que:
 - Un colectivo (p.ej., personas con discapacidad motora) recibe una fracción desproporcionada de falsas alertas.
 - O tiene un recall claramente inferior.
 - Se considera incumplida la exigencia de ausencia de sesgos del **art. 10 IA Act** y se activa el protocolo de parada y revisión.
- 5. Incumplimientos graves de RGPD / LOPD-GDD**
 - Uso de datos no previstos (p.ej., historiales clínicos, datos religiosos).
 - Fallos de seguridad que exponen datos operativos sensibles.
 - Falta de EIPD/DPIA o de participación del DPO en cambios relevantes.

Botón de parada de emergencia

En vuestra especificación (punto de “Gobernanza” y “botón de parada”) se define un mecanismo de emergencia:

- **Quién puede parar el sistema**
 - **Director/a del centro penitenciario.**
 - **Delegado/a de Protección de Datos (DPO)** de la Administración competente.
 - **Unidad central del Ministerio del Interior** responsable del sistema (en un despliegue multi-centro).
- **Cuándo se puede parar (ejemplos)**
 - Se superan de forma sostenida los umbrales de error:
 - Falsos positivos > **20 %** o FAR muy por encima de lo aceptable.
 - Caída del recall por debajo de los mínimos definidos para el nivel en uso.
 - Auditorías externas detectan **sesgo grave** contra un colectivo protegido.
 - Se produce una **brecha de seguridad** relevante (filtración, acceso no autorizado).
 - Usos manifiestamente indebidos (function creep, identificación biométrica, propósito punitivo directo).
- **Cómo se ejecuta la parada**
 - Activación de un **modo seguro**:
 - Suspensión de generación de nuevas alertas o marcado claro de que el sistema está en modo “solo monitorización / no fiable”.
 - Conservación segura de los logs y metadatos necesarios para auditoría.
 - **Notificación formal a**:
 - Ministerio del Interior.
 - DPO central y, si procede, autoridad de protección de datos competente.
 - Apertura de una **revisión extraordinaria** (técnica, legal y ética), con participación de:
 - Equipo técnico.
 - Auditores externos.
 - DPO y asesores jurídicos especializados en RGPD/LOPD-GDD.

7.3. Canal de reclamaciones y rendición de cuentas (versión comprimida)

En línea con el **art. 5.2 RGPD (responsabilidad proactiva)** y con las exigencias de la IA Act sobre supervisión y documentación, vuestra especificación contempla:

1. **Canal interno de reclamaciones**
 - Cualquier persona afectada indirectamente por el sistema (internos mediante su abogado, defensor del pueblo, sindicatos, ONG, etc.) puede:
 - Presentar una reclamación sobre **una alerta concreta** o el **uso general** de PrisonRisk-AI.
 - Características:

- **Respuesta motivada en ≤ 15 días** (objetivo que citáis).
- Revisión de los **logs de la alerta**, la explicación generada por el sistema y la decisión humana asociada.

2. Trazabilidad y registro

- Cada alerta queda registrada con:
 - Momento, módulo, tipo de riesgo.
 - Explicación proporcionada por el modelo.
 - Decisión final del funcionario.
- Esto permite:
 - Auditorías internas/externas.
 - Reconstruir casos para reclamaciones individuales o colectivas.

3. Rendición de cuentas periódica

- Informes periódicos (p.ej., semestrales) con:
 - Métricas globales (recall, precision, FP/FN, FAR).
 - Métricas de **equidad por subgrupos** (Equalized Odds, diferencias de recall y FPR).
 - Incidencias, paradas, recalibraciones y resultados de auditorías externas.
- Estos informes pueden compartirse con:
 - Ministerio del Interior.
 - Autoridad de Protección de Datos.
 - Órganos de control (Defensor del Pueblo, comisiones parlamentarias, etc.).

4. Corresponsabilidad y diseño institucional

- Conforme al **art. 26 RGPD**, se establece claramente quién es:
 - **Responsable del tratamiento** (Administración penitenciaria / Ministerio).
 - **Encargado del tratamiento** (proveedor tecnológico, si lo hay).
- Todos los actores firman acuerdos que incluyen:
 - Respeto a las **líneas rojas** anteriores.
 - Obligación de cooperar en auditorías y reclamaciones.

5. Referencia a fuentes

- Principios RGPD/LOPD-GDD:
 - [Youreurope – Data Protection](#)
 - [LOPD-RGPD – Cumplimiento LOPD](#)
- Obligaciones de supervisión y documentación en IA Act:
 - [AI Act Explorer](#)
- Enfoque **safetyist** y compromiso de transparencia y auditoría externa: sección “Postura macro” y “Gobernanza” de tu PDF.